

Vertrag zur Auftragsverarbeitung (AVV)

gemäß Art. 28 Datenschutz-Grundverordnung (DSGVO)

zwischen

dem Kunden / der Hundeschule

(im Folgenden „Auftraggeber“ genannt)

und

[DEIN FIRMENNAME / VORNAME NACHNAME]

[DEINE STRASSE UND HAUSNUMMER]

[DEINE PLZ UND ORT]

(im Folgenden „Auftragnehmer“ oder „Pfortencard“ genannt)

Präambel

Dieser Vertrag konkretisiert die datenschutzrechtlichen Verpflichtungen der Vertragsparteien, die sich aus der beauftragten Leistung (Bereitstellung der SaaS-Software „Pfortencard“) ergeben.

§ 1 Gegenstand und Dauer des Auftrags

(1) Gegenstand: Der Auftragnehmer verarbeitet personenbezogene Daten im Auftrag des Auftraggebers. Gegenstand des Auftrags ist die Bereitstellung von Speicherplatz und Rechenkapazität für die Verwaltung einer Hundeschule (Software-as-a-Service).

(2) Dauer: Die Laufzeit dieses Vertrags richtet sich nach der Laufzeit des Hauptvertrags (Nutzungsvertrag für Pfortencard). Er endet automatisch mit Kündigung des Hauptvertrags.

§ 2 Art und Zweck der Verarbeitung

(1) Art der Verarbeitung: Die Verarbeitung umfasst das Erheben, Erfassen, Ordnen, Speichern, Verändern, Auslesen, Abfragen, Verwenden, Übermitteln (Bereitstellen für den Auftraggeber), Löschen und Vernichten von Daten über die Cloud-Infrastruktur des Auftragnehmers.

(2) Zweck: Die Verarbeitung dient ausschließlich der Verwaltung von Kunden, Hunden, Terminen, Transaktionen und der Kommunikation der Hundeschule.

§ 3 Art der Daten und Kreis der Betroffenen

(1) Art der personenbezogenen Daten:

- Stammdaten (Name, Vorname, Anschrift, E-Mail, Telefonnummer)
- Hundedaten (Name, Rasse, Geburtsdatum, Chipnummer, Trainingsstand)
- Vertrags- und Abrechnungsdaten (gebuchte Kurse, gekaufte Wertkarten, Guthaben)

- Kommunikationsdaten (Chat-Nachrichten, hochgeladene Dokumente/Bilder)
- Protokolldaten (Login-Zeitpunkte, IP-Adressen)

(2) Kreis der Betroffenen:

- Kunden des Auftraggebers (Hundehalter)
- Mitarbeiter des Auftraggebers
- Interessenten

§ 4 Pflichten des Auftragnehmers

Der Auftragnehmer verpflichtet sich:

1. Daten ausschließlich weisungsgebunden zu verarbeiten.
2. Die Vertraulichkeit zu wahren. Personen, die zur Verarbeitung befugt sind, wurden zur Vertraulichkeit verpflichtet.
3. Die in **Anlage 1** beschriebenen technischen und organisatorischen Maßnahmen (TOMs) zur Datensicherheit zu gewährleisten.
4. Den Auftraggeber bei der Erfüllung von Betroffenenrechten (Löschung, Auskunft) technisch zu unterstützen.
5. Nach Abschluss der Erbringung der Verarbeitungsleistungen alle personenbezogenen Daten nach Wahl des Auftraggebers entweder zu löschen oder zurückzugeben, sofern keine gesetzlichen Aufbewahrungspflichten bestehen.

§ 5 Ort der Verarbeitung

Die Datenverarbeitung findet vorrangig in Rechenzentren innerhalb der Europäischen Union (Standort Frankfurt) statt. Sofern Daten in einem Drittland (z.B. USA) verarbeitet werden, garantiert der Auftragnehmer die Einhaltung eines angemessenen Datenschutzniveaus durch:

- Das Bestehen eines Angemessenheitsbeschlusses der EU-Kommission (z.B. **EU-US Data Privacy Framework**), oder
- Den Abschluss von EU-Standardvertragsklauseln (SCCs).

§ 6 Unterauftragsverhältnisse (Subunternehmer)

(1) Der Auftraggeber stimmt der Beauftragung der folgenden Unterauftragsverarbeiter zu:

Firma	Sitz	Dienstleistung
Supabase Inc.	USA	Datenbank-Hosting, Authentifizierung, Storage
Vercel Inc.	USA	Webhosting, Serverless Functions (Backend)

Stripe Payments Europe	Irland	Zahlungsabwicklung (eigener Verantwortlicher, hier nur techn. Weiterleitung)
-------------------------------	--------	--

(2) Der Auftragnehmer stellt sicher, dass mit diesen Unterauftragnehmern vertragliche Vereinbarungen getroffen wurden, die das gleiche Datenschutzniveau gewährleisten.

§ 7 Schlussbestimmungen

Sollten einzelne Teile dieses Vertrags unwirksam sein, so bleibt die Wirksamkeit des Vertrags im Übrigen davon unberührt. Es gilt deutsches Recht.

Anlage 1: Technische und Organisatorische Maßnahmen (TOMs)

gemäß Art. 32 DSGVO

Der Auftragnehmer gewährleistet die Sicherheit der Verarbeitung durch folgende Maßnahmen:

1. Vertraulichkeit (Zutritts-, Zugangs- und Zugriffskontrolle)

- **Verschlüsselung:** Alle Datenübertragungen erfolgen verschlüsselt mittels TLS 1.2/1.3 (HTTPS). Passwörter werden ausschließlich als kryptografische Hashwerte (bcrypt/argon2) gespeichert.
- **Authentifizierung:** Der Zugriff auf die Anwendung ist nur nach erfolgreicher Authentifizierung (E-Mail/Passwort) möglich. Es werden JSON Web Tokens (JWT) verwendet.
- **Berechtigungskonzept:** Strikte Datentrennung zwischen Mandanten (Multi-Tenancy). Jeder Datensatz ist mit einer **tenant_id** verknüpft; der Zugriff wird durch Row-Level-Security (RLS) oder anwendungsseitige Filterung strikt auf den eigenen Mandanten beschränkt.
- **Hosting:** Die physischen Server befinden sich in gesicherten Rechenzentren von zertifizierten Cloud-Anbietern (AWS via Supabase), zu denen der Auftragnehmer keinen physischen Zutritt hat.

2. Integrität (Weitergabekontrolle)

- Einsatz von digitalen Signaturen bei API-Zugriffen.
- Protokollierung von administrativen Zugriffen.
- Keine unbefugten USB-Schnittstellen oder physischen Datenträger im Einsatz.

3. Verfügbarkeit und Belastbarkeit

- **Backups:** Tägliche automatische Backups der Datenbank (Point-in-Time Recovery).
- **Redundanz:** Die Daten werden in professionellen Cloud-Umgebungen gespeichert, die über redundante Strom- und Netzwerkanbindungen verfügen.

- **Disaster Recovery:** Wiederherstellungspläne für den Fall eines Serverausfalls bestehen seitens der Cloud-Provider.

4. Verfahren zur regelmäßigen Überprüfung

- Der Auftragnehmer überprüft regelmäßig die Sicherheitseinstellungen der verwendeten Cloud-Dienste.
- Automatisierte Löschroutinen für inaktive Test-Accounts (Datensparsamkeit).
- Verpflichtung der Mitarbeiter auf das Datengeheimnis.